

Client: Altoro Mutual

Rapport d'audit de vulnérabilité

Business Confidential

table des matières

Déclaration de Confidentialité.....	3
Avertissement.....	3
Aperçu de l'évaluation.....	4
Composants de l'évaluation	4
Reconnaissance de Surface Externe	4
Surface Externe/Pentest Web	5
Exclusions du périmètre	5
Résumé exécutif.....	6
Résumé de la reconnaissance de surface	7
Résumé de la reconnaissance de surface	7
Résultats de la reconnaissance de surface externe.....	8
Résultats de l'analyse de vulnérabilités automatisée	9
Résultats de la validation manuelle (Exploitation).....	10
Remédiation	12
Rapports et Informations supplémentaires (Informative).....	13

Déclaration de Confidentialité

Ce document est la propriété exclusive de Argus Cyber et Altoro Mutual Il contient des informations confidentielles et exclusives. Toute duplication, redistribution ou utilisation, en tout ou en partie, sous quelque forme que ce soit, requiert l'accord préalable des deux parties, Argus Cyber et Altoro Mutual

Argus Cyber peut partager ce document avec des auditeurs sous accord de non-divulgaration afin de démontrer la conformité aux exigences des tests d'intrusion.

Avertissement

Un test de pénétration est considéré comme une photographie de la sécurité du système à un moment donné. Les résultats et recommandations présentés reflètent les informations recueillies durant l'évaluation et ne tiennent pas compte des modifications ou changements effectués après celle-ci.

Les engagements à durée limitée ne permettent pas une évaluation complète de tous les contrôles de sécurité. Ainsi, Argus Cyber a priorisé l'identification des contrôles de sécurité les plus vulnérables qu'un attaquant pourrait exploiter.

Argus Cyber recommande de réaliser des évaluations similaires sur une base annuelle, soit en interne, soit par des assessoirs tiers, afin de garantir la pérennité et l'efficacité des contrôles de sécurité.

Aperçu de l'évaluation

Du 20 avril au 24 avril 2026, Argus Cyber a été engagé par Altoro Mutual pour effectuer un audit de sécurité complet (Pentest Web) de son portail en ligne demo.testfire.net. Cette évaluation comprend une reconnaissance de surface externe, une analyse de vulnérabilités automatisée, ainsi qu'une validation et exploitation manuelle des failles applicatives identifiées.

L'entreprise souhaite identifier les technologies exposées, les mauvaises configurations de son serveur, ainsi que les vulnérabilités critiques de son code (comme les injections SQL ou les failles XSS) pouvant représenter un risque pour les données financières de ses clients.

Toutes les activités ont été menées selon les meilleures pratiques en matière de sécurité, en s'appuyant sur des méthodes adaptées aux cadres de tests recommandés par le NIST SP 800-115, l'OWASP Testing Guide (v4) et le Top 10 OWASP.

Les phases de l'évaluation incluent les suivantes :

- 1 **Reconnaissance Web** – Collecte et analyse des informations sur les technologies web utilisées par l'application, inspection des cookies, en-têtes HTTP et méthodes d'envoi de données.
- 2 **Analyse de Vulnérabilités (Automatisée)** – Utilisation de scanners de vulnérabilités web pour identifier les fichiers sensibles, répertoires cachés et mauvaises configurations.
- 3 **Validation et Exploitation Manuelle** – Utilisation d'un proxy d'interception (Burp Suite) pour capturer, analyser et manipuler les requêtes HTTP, validation manuelle des vulnérabilités critiques (SQLi, XSS, manipulation de trafic).
- 4 **Rapport** – Documentation des vulnérabilités confirmées, des preuves de concept et des recommandations de remédiation.

Composants de l'évaluation

Reconnaissance de Surface Externe

La reconnaissance de surface externe simule le rôle d'un attaquant tentant de collecter des informations accessibles publiquement afin d'évaluer la surface d'attaque d'un réseau interne, sans utiliser de ressources internes ni de connaissances privilégiées. Un ingénieur d'Argus Cyber effectue une collecte d'informations sensibles par intelligence en source ouverte (OSINT), incluant l'identification des technologies web (serveurs, langages de

programmation, frameworks), l'analyse des en-têtes HTTP, des cookies et des comportements côté client.

L'ingénieur procède également à des scans automatisés et à des validations manuelles pour identifier les vulnérabilités applicatives exploitables (injections SQL, XSS, mauvaises configurations) et documenter les preuves de concept.

Scope

Évaluation	Détails
Web Surface Externe/Pentest	demo.testfire.net

Exclusions du périmètre

À la demande d'Altoro Mutual, d'Argus Cyber a limité l'évaluation au portail demo.testfire.net uniquement.

Altoro Mutual autorise Argus Cyber à effectuer un audit de sécurité complet (Pentest Web) sur le domaine demo.testfire.net, incluant la reconnaissance, l'analyse de vulnérabilités automatisée et l'exploitation manuelle des failles identifiées.

Résumé exécutif

Ce rapport présente les résultats d'un audit de sécurité complet (Pentest Web) réalisé pour Altoro Mutual. L'objectif de cette évaluation est d'identifier les technologies exposées, les mauvaises configurations du serveur, ainsi que les vulnérabilités critiques du code applicatif pouvant représenter un risque pour les données financières des clients de la banque.

L'évaluation a révélé plusieurs vulnérabilités critiques affectant le portail demo.testfire.net, notamment :

- **Injection SQL (SQLi)** sur le formulaire d'authentification, permettant le contournement complet de l'authentification et l'accès non autorisé aux comptes clients.
- **Cross-Site Scripting (XSS) réfléchi** sur le champ de recherche, permettant l'exécution de scripts malveillants dans le navigateur des utilisateurs.
- **Exposition de technologies et configurations serveur** révélant des informations sensibles sur l'infrastructure sous-jacente.
- **Absence d'en-têtes de sécurité HTTP** critiques (X-Frame-Options, Content-Security-Policy, X-Content-Type-Options).
- **Cookies de session sans attributs de sécurité** (HttpOnly, Secure, SameSite).
- **Répertoires et fichiers sensibles exposés** accessibles publiquement.

Résumé de la reconnaissance de surface

Résumé de la reconnaissance de surface

Étape	Action	Recommandation
1	Reconnaissance des technologies web : Identification des technologies sous-jacentes du portail demo.testfire.net (serveur web, langages de programmation, frameworks) à l'aide d'outils WhatWeb .	Masquer les bannières de version des serveurs et technologies utilisées.
2	Analyse des en-têtes HTTP et cookies : Inspection des en-têtes de réponse HTTP, des cookies de session et des méthodes d'envoi de données côté client.	Ajouter les attributs HttpOnly, Secure et SameSite aux cookies.
3	Analyse de vulnérabilités automatisée : Utilisation de scanners de vulnérabilités web (Nikto, Burp Suite Scanner) pour identifier les fichiers sensibles, répertoires cachés et mauvaises configurations.	Corriger les mauvaises configurations du serveur. Supprimer ou restreindre l'accès aux fichiers et répertoires sensibles identifiés
4	Identification des sous-domaines et de la structure de l'application : Cartographie de l'application web et identification des points d'entrée potentiels.	Limiter l'exposition des pages et fonctionnalités non nécessaires. Implémenter un contrôle d'accès strict sur toutes les pages sensibles.
5	Analyse des certificats SSL/TLS : Vérification des certificats SSL/TLS associés aux services externes pour garantir leur validité.	Mettre à jour les certificats SSL/TLS périodiquement pour maintenir la sécurité des services.
6	Validation manuelle des injections SQL (SQLi) : Test des formulaires d'authentification et des champs de saisie pour détecter les vulnérabilités d'injection SQL.	Implémenter des requêtes paramétrées (prepared statements) et une validation côté serveur de toutes les entrées utilisateur.

7	Manipulation de trafic via proxy d'interception : Utilisation de Burp Suite pour capturer, analyser et manipuler les requêtes HTTP entre le navigateur et le serveur.	Implémenter une validation côté serveur de toutes les données, ne jamais se fier uniquement à la validation côté client
---	---	---

Résultats de la reconnaissance de surface externe

Description :

L'analyse de la surface externe du portail demo.testfire.net d'Altoro Mutual a révélé une exposition significative d'informations techniques pouvant être exploitées par un attaquant pour planifier et exécuter des attaques ciblées.

Impact :

Critique – Les informations collectées, combinées aux vulnérabilités identifiées, pourraient permettre à un attaquant de compromettre l'intégralité du système et d'accéder aux données financières des clients.

- **Domaine cible :**
 - demo.testfire.net
- **Adresse IP identifiée :**
 - 65.61.137.117
- **Technologies identifiées :**
 - Serveur web : Apache Tomcat
 - Langage de programmation : JSP (Java Server Pages)
 - Framework : Java EE
 - Système d'exploitation : Windows 2008 server r2
- **En-têtes HTTP notables :**
 - Bannière du serveur exposée (version du serveur web visible)
 - Absence de l'en-tête X-Frame-Options (vulnérabilité au clickjacking)
 - Absence de l'en-tête Content-Security-Policy
 - Absence de l'en-tête X-Content-Type-Options
 - Absence de l'en-tête Strict-Transport-Security
- **Cookies analysés :**
 - Cookie JSESSIONID : absence de l'attribut HttpOnly, absence de l'attribut Secure

Résultats de l'analyse de vulnérabilités automatisée

Vulnérabilité 1 : Injection SQL – Formulaire d'authentification

Attribut	Détail
Sévérité	CRITIQUE
CVSS	9.8
Localisation	Page de connexion : http://demo.testfire.net/login.jsp
Paramètre affecté	uid (nom d'utilisateur) et passw (mot de passe)
description	Le formulaire d'authentification est vulnérable à l'injection SQL. Un attaquant peut contourner l'authentification en injectant des charges SQL malveillantes dans les champs de connexion, obtenant ainsi un accès non autorisé aux comptes clients et à leurs données financières.

Vulnérabilité 2 : Cross-site scripting (XSS) - Champ de recherche

Attribut	Détail
Sévérité	HAUTE
CVSS	6.1
Localisation	Fonctionnalité de recherche : http://demo.testfire.net/search.jsp
Paramètre affecté	query (champ de recherche)
Description	Le champ de recherche ne filtre pas ni n'encode les entrées utilisateur, permettant l'injection de scripts JavaScript malveillants. Un attaquant peut exploiter cette faille pour voler les cookies de session, rediriger les utilisateurs vers des sites malveillants ou défigurer le contenu de la page.

Vulnérabilité 5 : Exposition de fichiers et répertoires sensibles

Attribut	Détail
Sévérité	MOYENNE
CVSS	5.3

Attribut	Détail
Localisation	Divers répertoires du serveur web
Description	Des fichiers et répertoires sensibles (fichiers de configuration, pages de test, répertoires de sauvegarde) sont accessibles publiquement, fournissant à un attaquant des informations précieuses sur l'architecture interne de l'application.

Résultats de la validation manuelle (Exploitation)

PoC 1 : Injection SQL – Contournement de l'authentification

Objectif : Démontrer qu'un attaquant peut contourner l'authentification en exploitant une injection SQL dans le formulaire de connexion

Étapes de reproduction :

1. Accéder à la page de connexion : <http://demo.testfire.net/login.jsp>
2. Dans le champ Username, saisir la charge suivante
' OR '1'='1' –
3. Dans le champ Password, saisir n'importe quelle valeur (ex: test)
4. Cliquer sur le bouton Login

Impact : Un attaquant peut accéder à n'importe quel compte client, consulter les soldes bancaires, effectuer des transferts non autorisés et compromettre l'intégrité des données financières.

PoC 2 : Cross-Site Scripting (XSS) Réfléchi – Champ de recherche

Objectif : Démontrer qu'un attaquant peut exécuter du code JavaScript arbitraire dans le navigateur d'un utilisateur via le champ de recherche.

Étapes de reproduction :

1. Accéder à la page de recherche ou utiliser la barre de recherche du portail
2. Dans le champ de recherche, saisir la charge suivante :
<script>alert('XSS')</script>
3. Soumettre la recherche

Résultat attendu : Une boîte de dialogue JavaScript affichant « XSS » apparaît dans le navigateur, confirmant l'exécution du script injecté.

Impact : Un attaquant peut exploiter cette faille pour :

- Voler les cookies de session (document.cookie) et usurper l'identité d'un utilisateur
- Rediriger les victimes vers des sites de phishing

- Modifier le contenu de la page affichée (defacement)
- Enregistrer les frappes clavier de l'utilisateur

PoC 3 : Manipulation de trafic via Burp Suite – Modification de requêtes http

Objectif : Démontrer qu'un attaquant peut intercepter et manipuler les requêtes HTTP pour altérer le comportement de l'application.

Étapes de reproduction :

1. Configurer Burp Suite comme proxy d'interception entre le navigateur et le serveur demo.testfire.net
2. Activer l'interception dans l'onglet Proxy > Intercept
3. Se connecter au portail avec des identifiants valides (ou via l'injection SQL)
4. Naviguer vers la fonctionnalité de transfert de fonds
5. Intercepter la requête POST de transfert
6. Modifier les paramètres de la requête (par exemple, le montant du transfert ou le compte destinataire)
7. Relâcher la requête modifiée vers le serveur

Résultat attendu : Le serveur accepte la requête modifiée et exécute le transfert avec les paramètres altérés par l'attaquant, confirmant l'absence de validation côté serveur.

Impact : Un attaquant peut effectuer des transferts de fonds non autorisés, modifier les bénéficiaires et compromettre l'intégrité des transactions financières.

Remédiation

Vulnérabilité 1 : Injection SQL (CRITIQUE)

Action	Équipe IT et Développement d'Altoro Mutual
Requêtes paramétrées	Remplacer toutes les concaténations de chaînes SQL par des requêtes paramétrées (Prepared Statements) dans l'ensemble du code applicatif.
Validation des entrées	Implémenter une validation stricte côté serveur (liste blanche) pour tous les champs de saisie. Rejeter les caractères spéciaux SQL (' , " , -- , ; , /* , */).
Principe du moindre privilège	Configurer le compte de base de données utilisé par l'application avec les permissions minimales nécessaires. Ne jamais utiliser un compte DBA pour les requêtes applicatives.
WAF	Déployer un Web Application Firewall (WAF) comme couche de défense supplémentaire contre les injections SQL.

Vulnérabilité 2 : Cross-Site Scripting – XSS (HAUTE)

Action	Équipe IT et Développement d'Altoro Mutual
Encodage des sorties	Implémenter un encodage systématique des sorties (HTML entity encoding) pour toutes les données renvoyées au navigateur.
Validation des entrées	Appliquer une validation côté serveur de toutes les entrées utilisateur avec des listes blanches de caractères autorisés.
Content Security Policy	Configurer une politique Content-Security-Policy (CSP) stricte pour empêcher l'exécution de scripts inline : Content-Security-Policy: default-src 'self'; script-src 'self'
Attribut HttpOnly	S'assurer que tous les cookies de session ont l'attribut HttpOnly pour empêcher leur accès via JavaScript.

Vulnérabilité 3 : Exposition de fichiers et répertoires sensibles (MOYENNE)

Action	Équipe IT et Développement d'Altoro Mutual
Restriction d'accès	Configurer le serveur web pour interdire l'accès aux répertoires sensibles et aux fichiers de configuration.
Directory listing	Désactiver le listing des répertoires sur le serveur web.
Fichiers inutiles	Supprimer tous les fichiers de test, de sauvegarde et de configuration non nécessaires en production.
robots.txt	Vérifier que le fichier robots.txt ne divulgue pas d'informations sur la structure de l'application.

Vulnérabilité 4 : Cookies de session non sécurisés (MOYENNE)

Action	Équipe IT et Développement d'Altoro Mutual
HttpOnly	Configurer tous les cookies de session avec l'attribut HttpOnly pour empêcher l'accès via JavaScript (protection contre le vol de cookies par XSS).
Secure	Configurer l'attribut Secure pour s'assurer que les cookies ne sont transmis que via HTTPS.
SameSite	Configurer l'attribut SameSite=Strict ou SameSite=Lax pour protéger contre les attaques CSRF.

Rapports et Informations supplémentaires (Informative)

Claude Kalawa fournit à ses clients toutes les informations collectées lors de l'évaluation. Cela inclut les données obtenues lors de la reconnaissance de surface et un rapport détaillé des conclusions. Pour plus d'informations, veuillez consulter les captures suivantes :

- AltoroMutual_WhatWeb_Scan.pdf
- AltoroMutual_BurpSuite_capture.pdf
- AltoroMutual_NIKTO_Scan.pdf

BUSINESS CONFIDENTIAL